后台架构规划与前后端联调报告

本报告面向项目负责人、前后端研发及运营人员，说明后台如何承接产品内容与用户业务、当前接口对齐到什么程度，以及下一步如何推进真实接入和上线。依据为当前源码、本轮独立数据库回归、真实浏览器操作与脱敏接口响应记录。

核验时间 2026-10-28 14:36 北京时间
测试批次 前后端全量回归与接口契约联调最终复验
浏览器 Playwright Chromium headless

结论

当前本机前后端主要业务已对齐，本轮 49 组全量回归通过，失败 0 组。其中包括后台发布到APP展示、前台提交到后台查询、社群审核后公开、老师需求受理回看、权限和完整记录导出。另有5项后端单元检查，已包含在全量套件内，不重复相加。

本轮浏览器记录到 174 次本地API响应，汇总为 35 个方法与路径组合。这里仅是浏览器实际发起的接口证据，不代表全部路径和每一种错误输入均被穷举。

本轮修复

发现的问题	当前结果
后台新增套餐未进入APP	新增套餐可见，并按后台发布顺序展示；归档后退出当前套餐列表
已归档会员内容仍可能从内置目录展示	会员课程展示增加已发布内容过滤
课程顺序未跟随后台排序	智慧馆依据服务端已发布列表排序
每日一句全部下架后回退内置文案	联网加载完成后显示准备中，不恢复已下架内容
记录写入失败被静默吞掉	保留本机记录，提示暂未同步到后台；可恢复连接后再次保存

交付边界

“已对齐”指当前本机实现及上述测试范围。真实AI调用、实体设备SDK与供应商授权、正式课程及老师资料、支付和真实会员生效、公共互联网部署均未完成外部验收。浏览器本地档案也不等于服务器全量档案，不能据此承诺完整跨设备恢复。

框架思路与职责边界

后台的目的，是把可信内容和运营决策变成稳定、可追溯的服务，支撑“认识自己、安顿自己、提升自己”的成长路径。内容管理与个人原始业务记录必须分开，不能用运营文案替代真实状态。



当前采用本地单体架构

APP为原生HTML、CSS和JavaScript组合构建；管理端为独立HTML管理台。两者通过同源 /api 接口访问Python标准库HTTP服务。Store负责SQLite连接、内容初始化、计时账本与审计；当前媒体二进制也保存在SQLite。系统绑定127.0.0.1，暂不作为公网生产服务。

层次	现有文件	职责
APP端	04_研发源码/app/r4/platform.js 等	界面、用户交互、pxApi、后台内容应用与客户端记录
管理端	04_研发源码/app/r4/time-bank-admin.html	内容表单、审核、角色、服务、导出、AI和设备配置
API和持久化	04_研发源码/app/r4/backend/server.py	路由、权限、校验、事务、计时、媒体与外部适配
构建	04_研发源码/app/r4/build.py	生成APP、查看页及后台；检查前后端页面脚本语法

设计原则

服务端负责最终权限与状态校验；发布范围由服务端定义；客户端保留离线体验但明确同步失败；接口不下发密钥；内容发布和回退留版本；业务操作留审计；尚未接入的外部能力明确显示未连接。

模块划分与权限规划

运营管理台现有18个入口

模块组	对应入口	主要职责
运营入口	运营概览	展示实际计数和常用工作入口
内容配置	每日一句 地图内容 抽卡卡池 冥想音乐 智慧课程 老师资料 设备供应商 签到音效 会员配置 会员权益	10类内容的草稿、发布、归档、排序及素材
业务处理	内容审核 服务需求 签到与计时	审核社群、处理老师需求、查询和导出业务元数据
追溯	内容版本 操作日志	恢复内容、回看关键操作
系统管理	账号与权限 AI与接口配置	角色分配、AI参数、设备密钥与字段映射

权限矩阵

角色	允许范围	关键限制
管理员	全部后台模块、账号角色及接口凭据	不得撤销自己的管理员权限
运营	内容、素材、审核、服务、记录、版本、日志	不能改角色或读取接口配置
审核员	概览、社群审核、操作日志	不能导出业务记录或管理内容配置
老师	APP自主发布与自身业务	不能直接进入管理员工作台
学员	APP学习、记录、申请、交流	只访问自身业务及公开内容
访客	公开内容、访客记录与计时	未登录不访问好友、服务和设备授权

权限执行位置

菜单显示只是第一层体验，后端require和admin分支再次校验。普通账号请求管理接口被拒绝；审核员不能访问原始记录导出；运营不能进入角色及密钥配置；好友消息要求双方已建立有效关系；媒体根据公开状态、作者身份和管理角色鉴权。

首位管理员与会话

首次初始化需要自行创建管理员，无预设密码。密码使用带随机盐的PBKDF2-SHA256散列；会话令牌随机生成，数据库保存令牌摘要。Cookie为HttpOnly、SameSite=Strict；当前为本地HTTP，公网阶段需HTTPS和Secure Cookie等额外部署工作。

数据模型与本地记录边界

当前共15张业务表，下面按职责合并说明。数据库初始化采用CREATE TABLE IF NOT EXISTS与默认内容首次写入，不会在每次重启时覆盖运营修改；这仍不是完整的版本化数据库迁移机制。

数据组	关键内容	责任边界
users sessions	账号 角色 密码散列 会话令牌摘要	身份与登录；不能直接导出密码或令牌
settings	AI主题与供应商配置	凭据仅在服务端；页面显示hasApiKey或hasSecret
contents revisions	内容kind/id/JSON/状态/排序 版本快照	后台编辑；已发布内容进入公开配置
posts media	发布正文 视频引用 上传二进制	作者编辑、运营审核；未公开媒体受保护
friendships messages	好友关系与私信正文	双方授权；管理导出不包含私信正文
service_requests	学员 老师 需求 日期 状态	学员提交；后台受理或结束
records	owner kind day data created	五类记录；同账号/类型/日期为复合主键
timer_runs	owner 起止 心跳 时区	每账号仅一个活动段；多窗口合并累计
devices measurements	授权连接 指标 数值 单位 测量时间	真实授权后接收；接口去重并映射字段
audits	操作者 动作 对象 说明 时间	关键变更、审核、导出等可追溯

服务器数据与浏览器数据

服务器保存账号、会话、公开配置、社群、好友消息、服务需求、设备、签到和自评记录、全局计时等。浏览器还保存收藏、偏好、练习及音乐时长、个人档案和本地预览数据；这些内容并非都具备服务器读回接口。游客写入按访客Cookie归属；登录后并未实现完整的访客档案迁移和跨账号本地隔离。

因此，当前联调结论不等于完整云同步。换设备、清理浏览器或切换账号时，不应承诺恢复全部本地档案。此项应在开放多账号或跨设备使用前优先完成。

计时和导出

全局计时心跳持续记账；离线不补算中间整段空白，多窗口不重复累计。管理列表展示最近500条记录并显示总数；完整JSON和CSV导出读取全部元数据及计时汇总，不包含自评正文、消息正文或密钥。SQLite在线备份脚本已验证完整性。

APP身份记录与智能接口

下表均以 /api 为前缀。JSON调用统一Content-Type，浏览器携带同源会话；媒体上传为二进制，使用独立格式。接口成功字段逐项对应实际调用，不能把body、data、items等概念互换。

方法	路径	前端调用者	请求与响应要点
GET	/api/public	APP启动 pxBootstrap	content settings user aiReady；只下发已发布配置，会员媒体按权限移除
GET	/api/auth/status	登录与后台初始化	user setupRequired；首次管理员入口状态
POST	/api/auth/setup	后台首次初始化	username password name → user；仅首次可创建管理员
POST	/api/auth/register 和 /login	APP账号表单及后台登录	账号凭据 → user 和会话Cookie；失败返回error
POST	/api/auth/logout	APP及后台退出	清理服务端会话及Cookie → ok
POST	/api/records	签到 抽卡 身体 生命 情绪	kind date data → ok；五种记录类型；签到和抽卡同日去重
POST	/api/time-bank/heartbeat	APP自动计时	zone → runs summary serverNow accountId zone
GET	/api/time-bank/state 和 /export	计时账本查询	当前账号或访客账本；不暴露其他人的累计
POST	/api/ai/chat	AI对话 pxAsk	messages 可选context → text；未配置明确报错

记录写入与身份边界

records按服务端会话或访客Cookie决定归属，前端不能提交owner冒充他人。身体、生命和情绪记录同日更新；签到和抽卡同日去重。管理导出只包含元数据与累计，不包含用户自述正文。

AI接入边界

APP提交messages和可选context，服务端统一转发。提示词、参考知识及密钥在后台配置。当前只有协议适配和未配置错误路径验收，不具备真实模型调用验收结论。

APP交流服务与素材接口

方法	路径	前端调用者	请求与响应要点
GET	/api/community/posts 和 /mine	公开动态与我的发布	items；公开流仅published，mine需登录
POST PATCH	/api/community/posts 和 /{id}	APP发布 编辑 撤回	title body mediaUrl status → id status；修改重审
GET POST PATCH DELETE	/api/friends 和 /{id}	好友申请 接受 移除	username 或status；items含incoming status
GET POST	/api/messages 和 /{friendId}	会话列表 读取与发送	items；发送body；双方必须为已接受好友
GET POST PATCH	/api/service-requests 和 /{id}	老师服务 提交及取消	teacherId date body → id status；查询限本人
GET POST DELETE	/api/devices /link /{id}	设备列表 授权与解除	provider deviceId map consent → id status；无授权不接收
POST	/api/integrations/measurements	供应商服务端推送	Bearer鉴权；connectionId metric value unit measuredAt；字段映射
POST GET	/api/media 和 /{id}	素材上传及音视频读取	上传为二进制；返回id url mime size；GET支持Range和权限
GET	/api/health	运行健康检查	ok version time；不返回凭据

统一响应与错误

状态	当前含义	前端应对
200	成功，按接口返回对象或items	更新真实状态，必要时重新读取配置
400	输入格式、枚举或参数无效	显示error，保留可修改内容
401 403	未登录、无权限或跨站	引导登录或拒绝，不伪造成功
404 409 413 415 416 429	不存在、冲突、超限、格式、Range或频率	按实际error提示，遵守上传和重试边界
500 502 503	本地异常或外部不可用	明确失败，本机保留时说明未同步

公开配置不返回管理凭据；普通用户不能直接读取受保护的会员课程媒体。设备数据推送使用供应商Bearer凭据，不以学员Cookie替代供应商鉴权。

后台接口与配置契约

方法	路径	授权角色	契约
GET	/api/admin/dashboard	管理员 运营 审核员	counts role；展示实际总量，不生成经营数据
GET POST	/api/admin/content/{kind}	管理员 运营	item status position → ok id；10类配置；修改保留历史
GET PATCH	/api/admin/posts 和 /{id}	管理员 运营 审核员	items 或 status reason；驳回/下架原因必填
GET PATCH	/api/admin/users 和 /{id}	仅管理员	角色变更；不能撤销自身管理员；不存在账号返回404
GET POST	/api/admin/settings	仅管理员	ai theme integrations；只返回hasApiKey/hasSecret，不回传密钥
GET PATCH	/api/admin/service-requests 和 /{id}	管理员 运营	items；status为accepted closed cancelled；不存在需求404
GET	/api/admin/records	管理员 运营	items timers total limit；最近500条元数据，明确总数
GET	/api/admin/records/export	管理员 运营	全部记录元数据及计时汇总；不含自评正文/私信/凭据；留审计
GET POST	/api/admin/revisions 和 /{id}	管理员 运营	查看版本及恢复；恢复内容和发布状态，保留当前版本
GET	/api/admin/audits	管理员 运营 审核员	操作时间 操作者 对象及说明；不记录密钥

格式与字段重点

APP记录使用kind、date、data；列表查询使用items；社群时间字段使用createdAt/updatedAt，部分管理接口仍返回数据库created毫秒值，前端分别转换。下一阶段应统一时间命名与错误代码，避免只依赖可变的中文error文案。

新增、发布、归档、排序通过admin/content传item、status、position；会员套餐只是内容配置，不能解释为真实支付或自动开通。接口地址、权限、字段摘要已另存机器可读契约对照JSON。

配置与操作追溯

修改已有内容保存历史快照，恢复时保留当前版本。角色变更、审核、设备授权、素材上传与导出等操作可追溯。后台与APP都不能通过接口读取明文密钥；配置编辑时留空保留原凭据，清除需要显式勾选。

关键业务联调闭环

内容配置到APP

运营编辑 → 保存草稿或发布 → 服务端校验并写内容和版本 → APP启动读取public → 应用已发布内容及排序 → 当前页面显示。归档后退出新内容列表；每日一句全空显示准备中。历史抽卡快照与历史预览记录可保留，不等于重新发布归档内容。

学员记录到后台

前台完成身体、生命、情绪、签到或抽卡 → 浏览器保存 → POST records → 后台按owner、kind、day持久化 → 管理页查询元数据或完整导出。网络失败时保留本地结果并提示未同步；当前没有自动重试队列、统一云端读回或全面跨设备恢复。签到和抽卡的同日重复不改写首条服务端结果。

自主发布与审核

作者上传素材 → 保存草稿或提交pending → 后台审核为published或rejected → 公开流只读取published → 作者修改已发布内容需重新审核。下架需要说明并退出公开流。原视频DOM在未发生数据变化的刷新中保留，避免刷新打断播放。

老师服务需求

已登录学员选择已发布老师 → 提交teacherId、未来或当日date、body → 后台出现pending需求 → 运营受理accepted或结束closed → 学员重新读取自身需求并看到真实状态。真实老师资料和服务排班仍需业务方提供。

设备与AI

设备供应商先配置，用户明确同意连接，才接受供应商凭据对应的测量推送；解除授权后拒绝继续写入。本轮通过本地HTTP模拟供应商验证，不代表真实硬件。AI消息由前台messages转换为服务端适配输入；适配单测验证请求及响应解析，未使用真实付费API。

好友与消息

按账号申请好友 → 对方接受 → 才能读取和发送双方消息；第三方账号无权访问。会话轮询仅在相应页面更新，保留正在输入的草稿。

全量回归与联调测试结果

49 组通过，0 组失败。另含5个后端单元测试；视口覆盖390×844、360×740、430×932，中英文、日夜、在线和离线入口、后台PC及手机布局。

全部写操作在独立SQLite测试库执行，测试完成后清理测试库。正式本地库未注入测试账号、视频、老师或520条批量数据。浏览器真实执行上传、审核、播放、CSV下载、套餐发布归档、记录提交与受理回看。

1. 统一主界面实际入口与窄屏控件 通过
2. 构建产物与输出目录 通过
3. 科技视觉结构与核心交互布局 通过
4. 实际文字对比度 自定义封面与偏好收起持久性 通过
5. 日夜配色可读性与全模块视觉快照 通过
6. 禅修播放暂停与设备等待状态 通过
7. 明亮默认主题与后续主动外观选择持久化 通过
8. 成长路径入口与觉察实践回看连续导航 通过
9. 首页结束位置与导航 通过
10. 全部已实现页面运行检查 通过
11. 手机尺寸与三大地图首屏 通过
12. 三大地图设备入口 通过
13. 四项自评保存与刷新 通过
14. 天赋特质逐题填写 通过
15. 人生课题与情绪同页保存 通过
16. 首页真实视口与核心练习入口 通过
17. 钟声签到与同日去重 通过
18. 自动滚轮与中心点停结果一致 通过
19. 收藏与课程筛选 通过
20. 音乐播放与控制 通过
21. 自动计时 隐藏与移动 通过
22. 计时浮层跟手拖动与最近侧磁吸 通过
23. 悬浮计时轻点切换 长条整体拖动与刷新保留 通过
24. 悬浮计时缩放边界 隐藏恢复与键盘操作 通过
25. 悬浮计时触摸点按与两种形态自由拖动 通过
26. 悬浮磁吸过渡与动画中再次拖动 通过
27. 旧版计时记录迁移不补算离线天数 通过
28. AI未配置状态与重试 通过
29. 中英文与日夜模式 通过
30. 账号初始化与权限隔离 通过
31. 自主发布 审核与越权修改 通过
32. 好友申请与真实会话权限 通过
33. 内容配置 发布与版本回退 通过
34. 计时不可暂停与多窗口去重 通过
35. 设备接口 授权和数据来源 通过
36. 素材上传格式与审核前可见性 通过
37. 跨站请求与敏感资料保护 通过
38. 后台配置实际同步到APP 通过
39. 运营 审核员和老师权限 通过
40. 并发 跨天 持久化及AI适配单测 通过
41. 后台音频发布与会员媒体保护 通过
42. 浏览器真实视频发布 审核与播放 通过
43. 后台查找筛选 完整导出与供应商编辑 通过
44. 统一后台界面完整流程 通过
45. 离线独立页面与负责人查看页 通过
46. 发布契约 新增套餐 归档内容与排序联调 通过
47. 记录接口 实际提交与断网反馈联调 通过
48. 老师需求 前台提交 后台受理 前台回看联调 通过
49. 浏览器运行错误汇总 通过

浏览器API证据：174 次响应，35 个方法/路径组合。证据只记录方法、脱敏路径和状态码，不记录Cookie、密钥或正文。预期401/403/404及模拟503用于失败路径断言，不能简单把出现非200计为系统故障。

有限测试不能证明绝对无缺陷。未覆盖公网、真实AI、实体手机、真实硬件、生产规模压力与真实支付。浏览器检查通过不等于用户视觉认可。

实施规划与验收顺序

以下为后续建设规划，不作为当前已完成功能。先解决数据归属、外部授权和部署基础，再接入真实服务；不设未经确认的上线日期。

阶段	工作内容	完成标准
P0 公开与多账号使用前	完善账号级本地隔离、访客迁移、记录读回、断网待同步队列与冲突处理；统一状态与时间字段	换账号不串档；断网重连可恢复；跨设备数据范围有明确验收用例
P0 正式部署前	数据库迁移版本、恢复演练、TLS与Cookie配置、生产服务器、部署配置和日志监控	重启升级与恢复可复现；无公开初始化或凭据暴露；不使用当前回环开发服务直接对外
P1 内容运营准备	真实授权内容、老师资料、媒体；服务器分页与检索；来源和授权信息管理	运营提供来源/授权/可收费与AI引用边界；内容发布、下架、检索与容量验证
P1 外部服务联调	AI供应商、模型与额度；设备品牌SDK、授权与指标样例；支付沙箱和会员权益模型	逐一测试成功、失败、超时、取消、撤权、支付幂等和退款，留真实证据
P2 持续运营	媒体迁移对象存储、异步任务、缓存、统一可观测性与规模评估	依据真实媒体体量和并发数据决定拆分，不提前声称支持高并发

需要业务方提供

AI服务账号与允许使用的模型；设备品牌、SDK、供应商接口和合法测试设备；老师身份及授权资料；课程、音频、视频和内容使用范围；支付主体、商户配置与沙箱；部署环境、域名及运营责任人。密钥应通过服务端配置，不放入评审文件或前端源码。

维护与发布流程

需求与契约变更 → 修改同一项目源码 → 构建前检查 → 独立数据库全量回归 → 查看请求证据及截图 → 备份 → 更新说明和清单 → 验收后再部署。每次完成模块继续执行全量回归，失败先修复重跑。

交付与证据入口

文件	用途
05_后台与研发说明/后台管理使用手册.txt	运营实际操作步骤
06_验证与后续工作/本轮全量回归结果.json	当前批次、历史批次、逐项结果与构建哈希
06_验证与后续工作/前后端接口实测证据.json	浏览器API方法、脱敏路径与状态码
06_验证与后续工作/前后端接口契约对照表.json	APP与管理端接口字段和授权摘要
06_验证与后续工作/联调-老师需求受理回看.png	老师需求闭环浏览器截图
07_历史版本仅供追溯/前后端契约对齐前时间戳.zip	修改前源码与构建回退存档，不含运行数据库

当前后台入口 http://127.0.0.1:8765/admin 。启动方式和数据库备份见使用手册。报告核验对象是本项目实际源码和构建产物，历史截图与旧报告不代替本轮证据。